Access Control Policy

POL-COMP-004 · Version 3.3 · Effective 2025-04-01

1. Purpose

The purpose of this Access Control Policy is to define the requirements for managing access to Acme Corp’s systems, specifically the Auth Service, Secrets Vault, Customer Portal, and API Gateway. This policy aims to ensure that access to sensitive information and systems is restricted to authorized individuals only, thereby safeguarding the integrity, confidentiality, and availability of Acme Corp's resources.

2. Scope

This policy applies to all employees, contractors, and third-party service providers who require access to Acme Corp’s production systems, including but not limited to the Auth Service, Secrets Vault, Customer Portal, and API Gateway. All access must comply with this policy and related documents.

3. Policy Statements

3.1 Principle of Least Privilege

Access to production systems follows the principle of least privilege. Individuals are granted the minimum level of access necessary to perform their job functions. This reduces the risk of unauthorized access to sensitive data and systems.

3.2 Access Reviews

Access reviews for production systems are performed quarterly. The purpose of these reviews is to ensure that access rights remain appropriate and to identify any unauthorized access. The owning team is responsible for conducting these reviews and remediating any identified issues.

3.3 Multi-Factor Authentication (MFA)

Multi-Factor Authentication (MFA) through the Auth Service is required for all production access. Users must authenticate using at least two distinct factors to ensure that only authorized personnel can access sensitive systems. The MFA setup must comply with the standards outlined in the relevant documentation.

3.4 Privileged Access

Break-glass privileged access is issued from the Secrets Vault for use in emergency situations where immediate access is required. This access is temporary and expires after 4 hours. The process for requesting and approving break-glass access must follow the

guidelines established in the relevant operational procedures.

3.5 Revocation of Access for Leavers

Access for employees who are leaving Acme Corp is revoked within 24 hours of their last working day. The on-call engineer must ensure that all access rights are deactivated promptly to mitigate the risk of unauthorized access after an employee departs.

3.6 Access Logging and Monitoring

All access to production systems must be logged and monitored. Logs should include user identity, timestamp, access type, and any actions performed. The logs must be retained in accordance with the Data Retention Policy (POL-COMP-001) and reviewed regularly for suspicious activity.

3.7 Role-Based Access Control (RBAC)

Access to systems will be managed through Role-Based Access Control (RBAC). Roles will be defined based on job functions, and users will be assigned roles that grant access rights commensurate with their responsibilities. The owning team must maintain an updated list of roles and associated access rights.

3.8 Third-Party Access

Third-party service providers requiring access to Acme Corp’s production systems must be vetted and approved prior to access being granted. Contracts must include clauses that stipulate compliance with this Access Control Policy and any related security requirements.

4. Roles and Responsibilities

- The owning team is responsible for implementing and maintaining access controls in alignment with this policy.
- The on-call engineer is responsible for ensuring that break-glass access is issued, monitored, and revoked within the stipulated timeframe.
- All users are responsible for adhering to this policy and reporting any suspected security incidents immediately.
- The Incident Commander is responsible for overseeing incident response procedures should a security breach occur.

5. Exceptions

Requests for exceptions to this Access Control Policy must be documented and submitted to the governing body for approval. Exceptions will be evaluated on a case-by-case basis and must not compromise the security of Acme Corp’s systems.

6. Enforcement

Violations of this policy may result in disciplinary action, up to and including termination of employment or contract. It is the responsibility of all employees and contractors to understand and comply with this Access Control Policy. The governing body reserves the right to audit access rights and compliance with this policy regularly.

7. Related Documents

- POL-COMP-001: Data Retention Policy
- POL-COMP-002: Acceptable Use Policy
- POL-COMP-005: Encryption and Key Management Policy
- POL-COMP-006: Change Management Policy